اللاسلكي والمفتاح في زمن الصياح

Lecture 4 — Wireless Network Security

Q/ Why is security even more essential in wireless networks ?

- Wireless signals aren't contained in a wire: **any device in range can receive the traffic**. Wired LAN traffic is often unencrypted, but traffic between wireless clients and the **AP must be encrypted**.

> **Authentication** : verifying the identity of a user and/or device. Clients must authenticate before associating with an AP; ideally clients also authenticate the AP (to avoid a **malicious AP** and man-in-the-middle).

> **Encryption** : scrambling a message so only the sender and intended recipient can read it (both must use the same protocol).

> **Integrity** : the message isn't modified by a third party — checked with a **MIC (Message Integrity Check)**.

Q/ How does a MIC work ?

1. Sender calculates a MIC and attaches it.
2. Sender encrypts the message + MIC and sends the frame.
3. Recipient decrypts and **recalculates** the MIC with the same protocol.
4. Recipient **compares**: same → not tampered; different → **discarded**.

More accurate: a MIC helps **detect** that integrity was compromised.

Foundations

Layer	Name	Job
1	Physical	Sends/receives radio waves
2	Data Link	Frames; MAC addresses pick the local device
3	Network (IP)	Routes packets between networks

Wireless security (authentication, encryption, integrity) is a **Layer 2** concern; Layer 3+ don't know which protocol is used.

Frame : the basic unit of data at Layer 2.

MAC address : a **48-bit** hardware address (00:1A:2B:3C:4D:5E) used to deliver frames.

802.11 : the technical name for Wi-Fi (IEEE WLAN standards).

BSS (Basic Service Set) : an AP plus its clients, identified by the **BSSID** (the AP radio's MAC).

SSID : the human-readable network name.

ESS (Extended Service Set) : several BSSs sharing one SSID, so clients **roam** between APs.

Infrastructure mode : clients communicate through an AP. **IBSS / ad hoc** : clients talk directly, no AP.

Symmetric	Asymmetric (public-key)
One shared secret key	Public key (anyone) + private key (owner)
Fast	Far slower
Bulk data: WEP, TKIP, CCMP, GCMP	Briefly: authenticate and agree on a symmetric key (inside PEAP/EAP-TLS TLS tunnels)

Block cipher	Stream cipher
Encrypts fixed-size chunks; needs a mode of operation	Continuous keystream XORed with plaintext bit by bit
AES — used by CCMP, GCMP (in counter mode, acting like a stream cipher)	**RC4** — used by WEP, TKIP

XOR : 1 if the bits differ, 0 if they match; XOR-ing the same keystream twice cancels out (plaintext ⊕ keystream = ciphertext; ciphertext ⊕ keystream = plaintext).

> **Digital signature** : (1) hash the document, (2) encrypt the hash with the signer's **private key**, (3) anyone verifies with the signer's **public key**.

Reversal: encryption uses the **recipient's public key**; a signature uses the **signer's private key**.

> **Certificate Authority (CA)** : a trusted third party that signs a document binding a public key to an identity. This trust structure is **PKI**.

Hash function	MIC
No secret key — anyone can recompute	Uses a **shared secret key**
Protects against accidental corruption	Protects against **deliberate tampering**

In general crypto a MIC is also called a **MAC (Message Authentication Code)** — unrelated to a MAC address.

> **Pairwise key** : each client's own key with the AP — clients can't decrypt each other's **unicast** traffic.

> **Group key** : shared by all clients, refreshed by the AP — used only for **broadcast/multicast**.

Authentication methods (least → most secure)

> **Open authentication** : the AP accepts every request, no credentials. Not secure alone, but combined with other methods (e.g. public Wi-Fi + web login page).

> **WEP (Wired Equivalent Privacy)** : authentication **and** encryption with **RC4**; shared key of **40 or 104 bits + 24-bit IV = 64 or 128 bits**. Easily cracked — **don't use**.

Q/ How does WEP challenge-response authentication work ?

1. **Challenge**: AP sends a challenge phrase.
2. **Response**: client encrypts it with the WEP key and returns it.
3. **Comparison**: AP compares with its own encryption; match → same key → authenticated.

EAP (Extensible Authentication Protocol) : not one protocol but a **framework** that EAP methods (LEAP, EAP-FAST, PEAP, EAP-TLS) build on.

802.1X : **port-based network access control** — limits access until the client authenticates (wired and wireless).

802.1X entity	Role	In a WLAN
Supplicant	Device that wants to connect	Client laptop
Authenticator	Device that provides access	AP (or the **WLC** in split-MAC)
Authentication server	Checks credentials, permits/denies	Usually **RADIUS**

Two stages: **open authentication** to associate, then **EAP authentication** for network access (only EAP traffic allowed meanwhile).

LEAP (Cisco) : username + password; **mutual** challenge phrases; **dynamic WEP keys**. Still **vulnerable**.

EAP-FAST (Cisco) : (1) server gives a **PAC** (Protected Access Credential), (2) PAC builds a **TLS tunnel**, (3) client authenticated **inside** the tunnel.

PEAP : server presents a **digital certificate** → authenticates the server and builds the TLS tunnel; client authenticated inside (e.g. **MS-CHAP**).

EAP-TLS : certificates on the **server and every client**; mutual certificate authentication, no inner client authentication. **Most secure, hardest to deploy**.

Method	Developer	Server authenticated by	Client authenticated by	Status
LEAP	Cisco	Mutual challenge phrase	Username/password + challenge	Vulnerable — don't use
EAP-FAST	Cisco	PAC → TLS tunnel	Inside the tunnel	Secure
PEAP	—	Server certificate → TLS tunnel	Inside the tunnel (MS-CHAP)	Secure; easier than EAP-TLS

Method	Developer	Server authenticated by	Client authenticated by	Status
EAP-TLS	—	Server certificate	**Client certificate**	**Most secure**; hardest

Encryption and integrity methods

> **TKIP (Temporal Key Integrity Protocol)** : a **temporary fix** based on WEP for old hardware; used in **WPA**.

Q/ What does TKIP add to WEP ?

1. A **MIC** for integrity.
2. **Key mixing**: a unique WEP key per frame.
3. IV doubled **24 → 48 bits**.
4. MIC includes the **sender MAC address**.
5. **Timestamp** against replay attacks.
6. **Sequence number** per source MAC (wrong counter → frame dropped).

> **CCMP (Counter Mode CBC-MAC Protocol)** : **AES counter mode** encryption + **CBC-MAC** integrity; used in **WPA2**; needs hardware support.

> **GCMP (Galois Counter Mode Protocol)** : **AES counter mode** + **GMAC** integrity; more secure and efficient (higher throughput); used in **WPA3**.

Protocol	Encryption	Integrity	Used in
TKIP	RC4 (WEP + per-frame key mixing, 48-bit IV)	MIC (incl. sender MAC)	WPA
CCMP	AES counter mode	CBC-MAC	WPA2
GCMP	AES counter mode	GMAC	WPA3

WPA, WPA2, WPA3

> **WPA (Wi-Fi Protected Access)** : standard sets of security protocols certified by the **Wi-Fi Alliance** (the first is "WPA", not WPA1).

Personal mode	Enterprise mode
Pre-shared key (PSK) — home Wi-Fi password, SOHO	**802.1X + authentication server** with EAP methods (PEAP, EAP-TLS…)
PSK never sent over the air; four-way handshake derives keys	Any EAP method supported

Q/ What extra features does WPA3 add ?

1. **PMF (Protected Management Frames)**: protects management frames from eavesdropping/forging — optional in WPA2, **mandatory** in WPA3.
2. **SAE (Simultaneous Authentication of Equals)**: protects the four-way handshake in Personal mode.
3. **Forward secrecy**: captured frames can't be decrypted later.

	WPA	WPA2	WPA3
Encryption & integrity	TKIP	CCMP (AES-CTR + CBC-MAC)	GCMP (AES-CTR + GMAC)
Personal mode	PSK	PSK	PSK + **SAE**
Enterprise mode	802.1X + EAP	802.1X + EAP	802.1X + EAP
Protected management frames	No	Optional	**Mandatory**
Forward secrecy	No	No	**Yes**

Summary of Advanced Cybersecurity L4: Wireless Network Security. Built only from the lecture file; check the original slides for anything you're unsure about.